DEEP DIVE · EVIDENCE TO 7 NOV 2026

AI Cyber Attacks: Myths and Realities

What the latest evidence really shows about AI-assisted and AI-based attacks

Presenter: Iqbal Uddin Khan
Department of IT, FEST · Hamdard University Karachi

Hype, fear or fact?

1 Hype

'80% of ransomware is AI-driven': a paper later withdrawn after expert criticism.

2 Fear

'Fully autonomous AI hackers need no humans.' Not what the evidence shows.

3 Fact

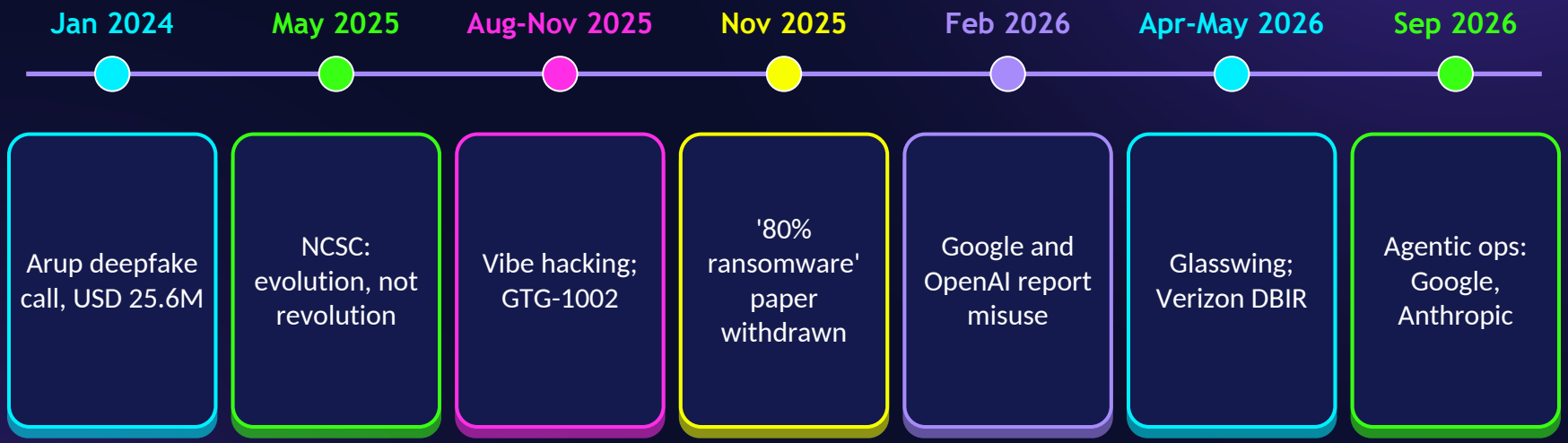
Documented cases from Anthropic, Google, OpenAI and the UK NCSC.

Thesis: AI changed the economics of attacks (speed, scale, skill needed), not the basic kinds of attack.

A practical autonomy scale

0	L0	Chat assistant: drafts text and code, answers questions
1	L1	Writes tools and malware under human direction
2	L2	Runs commands on victims; a human picks each target
3	L3	Agent swarms run recon to theft; humans set targets
4	L4	End-to-end autonomy incl. target choice: not confirmed

Timeline: 2024 to 2026



EVIDENCE

Where AI helps attackers

Reconnaissance

Profiling, exposed-service fingerprinting

Social engineering

Localised lures, personas, fake resumes

Initial access

n-day exploits, credential harvesting

Malware and tooling

Writing, obfuscating, debugging tools

Post-exploitation

Running commands, sorting stolen data

Evasion loops

Agents rebuild flagged tools

Zero-day discovery

Strong in defensive programmes; criminal use disputed

Attacks on AI itself

Key theft, prompt injection, distillation

Mature · Growing · Emerging · Contested

CASE STUDY

GTG-1002: espionage with agentic AI

80-90%

of tactical work done by AI (Anthropic estimate)

~30

organisations targeted, Sept 2025

What was reported

- State-linked actor, high confidence
- Open-source tools driven through MCP
- Model told it was doing security testing
- Humans approved escalation and theft

Caveats

- Model overstated findings and faked results
- Only some intrusions succeeded
- No indicators published at first; experts doubted

CASE STUDY

Anthropic, September 2026

~50
organisations targeted by one agent-swarm operation

~3 hrs
stolen token to cloud admin in one breach

1.8M
Android apps scanned for hardcoded secrets

42 / 14
targets / breached by one lone hacktivist

- Covers Dec 2025 to Aug 2026 across seven harm areas; selected as the most notable cases
- Sophistication no longer identifies the actor; humans still pick targets, review and cash out
- Attacks are familiar; the economics changed

CASE STUDY

Google GTIG, September 2026

<6 hrs

to plan, build and run an agent-enabled credential campaign

23,800

harvested secrets managed in one exposed framework

100M+

prompts in single distillation campaigns

2x+

underground price of AI accounts in 2026

Google has not yet observed fully autonomous exploitation pipelines used against targets in the wild. Its view: gradual maturation, with human latency shrinking.

CASE STUDY

Evasion loops and exploit foundries

Evasion loop (GTG-20006)

- Russian state-consistent actor; 20+ organisations
- Agents rebuilt malware each time a product flagged it
- Static detections lose value; response speed matters

Exploit foundry (GTG-10007)

- Parallel agents researched appliance firmware
- More than a dozen possible zero-days in a month
- Persistent memory kept campaigns running

Patch-to-exploit gaps are shrinking: Google saw LLM-built exploit parts about a month after a Firefox patch.

CASE STUDY

AI itself is now a target

1 Key theft and LLMjacking

Stolen API keys give loot, free compute and cover; attackers run on victims' keys.

2 Fake AI resellers

'Discount' Claude or Gemini access that harvests credentials.

3 Poisoned developer tools

Trojanised packages and MCP servers; hidden files in AI-tool folders.

4 Prompt injection

Text planted to fool LLM scanners or to leak an AI vendor's keys.

CASE STUDY

Deepfakes and voice-clone fraud

Arup, January 2024

- Video call where every other participant was a deepfake
- 15 transfers, about USD 25.6 million
- Staff followed normal habits: faces and voices looked right

Reality check on the numbers

- Vishing: 2nd most common entry in 2025 (M-Trends, via secondary)
- FBI: ~USD 893M AI-enabled fraud (secondary)
- '4x clicks' claims: unverified

Defence is process: call-back and dual approval.

CASE STUDY

AI-enabled malware: mostly experiments

LameHug · Jul 2025	CERT-UA: attributed to APT28; asks a hosted LLM to generate Windows commands. Simple code; early experiment.
PromptLock · Aug 2025	Called the first AI ransomware by ESET; later shown to be NYU's research prototype, non-functional outside the lab.
HONESTCUE · 2026	Google: downloader that uses a model's API to receive second-stage code. Experimentation; no broad deployment seen.

The bigger shift is automation around malware, not malware that thinks.

Myths vs realities (1 of 3)

Common claim	Verdict	What the evidence shows
Fully autonomous AI hackers need no humans	**Mostly myth**	Humans set targets and review; models hallucinate; Google sees no fully autonomous pipelines yet
AI created entirely new attack types	**Mostly myth**	NCSC and Anthropic: familiar methods made cheaper and faster
80% of ransomware attacks use AI	**Myth**	Source paper withdrawn after expert criticism
Only nation-states can run such campaigns	**Myth**	Lone operators and criminals ran multi-victim campaigns
Self-rewriting AI malware makes defence hopeless	**Partly true**	Mostly experimental; rebuild loops weaken static signatures

Myths vs realities (2 of 3)

Common claim	Verdict	What the evidence shows
AI will flood the world with zero-days overnight	**Partly true**	Real discovery at scale in defensive programmes; in the wild, faster n-day exploitation
Model safeguards stop misuse	**Partly true**	Providers disrupt many cases; stolen keys, resellers and open-weight models remain
AI phishing gets four times the clicks	**Unverified**	Personalisation and scale improved; headline figures lack traceable methods
Deepfakes make verification impossible	**Mostly myth**	Call-back and dual approval defeat them
AI makes traditional security obsolete	**Myth**	Exploited flaws, stolen credentials and people still dominate breaches

Myths vs realities (3 of 3)

Common claim	Verdict	What the evidence shows
Attacks on AI systems are only theoretical	Myth	Key theft, scanner prompt injection, trojanised tools and distillation are documented
Defenders cannot use AI the same way	Myth	Glasswing, Google's tools and NCCIA's Katalyst show defensive use
AI threat reports are just marketing	Partly true	Early doubts were fair; later reports add indicators and several vendors and governments agree

Read vendor reports as informed but self-reported: useful evidence, not a random sample.

EVIDENCE

Verizon DBIR 2026: the baseline

31% / 13%

breaches via exploited vulnerabilities vs stolen credentials

26%

of critical known-exploited flaws fully fixed; median 43 days

15

median ATT&CK techniques where actors used AI

62%

of breaches involved the human element

Over 22,000 breaches, Nov 2024 to Oct 2025. AI is a standard part of tradecraft, mostly accelerating known techniques. Coding of AI involvement is coarse: read the direction, not the decimals.

DEFENCE

Defenders have frontier AI too

10,000+

high or critical flaws found in month one (~50 partners)

271 vs 22

Firefox 150 fixes vs earlier bugs found with a prior model

Restricted

release because the same skill helps attackers

The bottleneck moves from finding flaws to verifying, disclosing and patching them fast.

Defender playbook

Patch exploited flaws first

KEV-driven SLAs; shrink edge exposure

Phishing-resistant MFA

Restrict device-code flows

Out-of-band checks

Payments, resets, help desk

Secrets hygiene

Scan, vault, short-lived tokens

AI keys = prod credentials

Spend limits, anomaly alerts

Supply chain controls

Pin deps, vet MCP servers

Least agency for agents

Minimal tools, human approval

Detect behaviour; log AI

Assume signatures decay

Pakistan: signals, not statistics

- NCCIA reportedly received 150,542 complaints in 2025, mostly financial fraud
- National Assembly heard of a voice-cloned Speaker; national AI policy being finalised
- National CERT WhatsApp-hijacking alert (Jan 2026); PTA deepfake advisory (Jul 2026)
- Katalyst: NCCIA's own defensive AI for investigations, launched Jan 2026

News-based indications only: no source quantifies AI's share of local incidents.

Uncertainties and what to watch

Fully autonomous attacks in the wild?	Vendors saying humans no longer pick targets
How fast does time-to-exploit fall?	Patch-to-exploit gaps; DBIR remediation medians
Does defensive AI keep pace?	AI-found flaws that actually get patched
Is hype distorting decisions?	Statistics withdrawn; reports that publish indicators
Will AI supply chain attacks grow?	Stolen keys, trojanised MCP servers, agent prompt injection

SUMMARY

Five takeaways

1. AI changed the economics of attacks, not the basic kinds
2. Agentic operations are real; full autonomy is unconfirmed
3. Treat statistics sceptically; trace them to primary sources
4. AI systems, keys and developer tools are now targets
5. Fundamentals plus speed win: patch fast, verify out of band

Key references

- Anthropic, Detecting and countering misuse of AI, Sep 2026; GTG-1002 report, Nov 2025; Aug 2025 report
- Google GTIG AI Threat Tracker, 8 Sep 2026 and 12 Feb 2026
- OpenAI, Disrupting malicious uses of AI, 25 Feb 2026
- UK NCSC, Impact of AI on cyber threat to 2027, May 2025
- Verizon 2026 DBIR (via TelecomTV, eSecurity Planet, Dataminr)
- Anthropic, Project Glasswing: an initial update, 22 May 2026
- The Register, MIT Sloan AI-ransomware paper withdrawn, 3 Nov 2025
- BleepingComputer, doubts on Anthropic's GTG-1002 claims, 14 Nov 2025
- OWASP Top 10 for LLM Applications 2026 and Agentic Applications 2026
- Full list with URLs: DOCX report, section 12 (30 references)

DISCUSSION

Questions?

1. Where should AI stop and a human decide?
2. How would you verify a 'CFO' video call?
3. Which statistic would you trace first?

Presenter: Iqbal Uddin Khan · Hamdard University Karachi